



2016 中国互联网安全大会
China Internet Security Conference

协同联动 共建安全⁺命运共同体

Multivariate Solutions to Passive DNS Challenges

Merike Kaeo | CTO Farsight Security
merike@fsi.io



中国互联网安全大会



360互联网安全中心

Agenda

- Typical Passive DNS Use
- Passive DNS Challenges
- Multivariate Solutions
- Understanding WHOIS and Geolocation
- Malicious Campaigns during Public Events



中国互联网安全大会



360互联网安全中心

TYPICAL PASSIVE DNS USES

- Start with a known/observed bad data point
 - Domain name
 - Nameserver
 - IP address/CIDR
 - ASN
- Use Passive DNS to find other IPs or domain names that share the same resources
- Leverage reputation locality but carefully review what you've found

- Use a single point of commonality as a way to identify related domains
 - SAME exact IP?
 - SAME exact nameserver?
 - SAME exact domain name used over time (if you are interested in the set of IPs that a name has been using)
- Each relies on a single attribute, exactly matched

- Many related domains coexist on a single IP(or small CIDR block), with no innocent 3rd party domains
- Many related domains use the same set of dedicated name servers, with no innocent 3rd party domains
- The malicious user is apparently stubbornly fond of a favorite domain



中国互联网安全大会



360互联网安全中心

PASSIVE DNS CHALLENGES

When Simple pDNS Does NOT Work

- ZERO interrelated data points – e.g. “lone wolf” domain names, IP addresses, name servers, etc.
- Too many related resources
- Malicious resources are comingled with innocent 3rd party resources

The cybercriminal reuses **NOTHING** across sites

- Every IP address used to send SPAM or host content is totally unrelated to any other Ips the criminal uses
- Every domain name is registered using:
 - A diverse assortment of registrars, one or two at a time
 - Unique name servers (installed and operated on unique IPs)
 - Unique/fictitious (or concealed) POC details
 - Unique (or anonymous) payment details

- Example #1: Provider fails to document IP reassignments/reallocations in IP WHOIS or rWHOIS, and an abuser repeatedly moves (or is moved) around a single large network block, or among multiple smaller blocks.
- Example #2: WHOIS POC details are concealed by a WHOIS proxy/privacy service

- Look for other characteristics that may not be obfuscated, or seek to strip away anonymity
- Examples
 - If nameservers service a large number of domains, and thus are not a useful attribute to try to follow, look at the IP address(es) the bad domain is hosted on, instead.
 - If a domain is demonstrably engaged in phishing or other clearly illegal behavior, some privacy/proxy protection services have terms of service which allow the provider to unilaterally strip privacy protections.

- With Reverse Proxies, everything seems to “live on the reverse proxy’s IP addresses”
- Carefully scrutinize non-A/non-AAAA DNS records that may be present (e.g. MX, TXT, etc)
- Reverse proxy operators are also potentially a terrific target by law enforcement

- Encoded URLs, unique to each specific recipient
- Because each URL is unique to each recipient, visiting the URL (typically to investigate the site being spamvertised) means:
 - Confirming you've opened the message and clicked through (establishing a potential argument that you've "opted-in")
 - May result in you "using-up" a URL coded for one-time-use (try the same URL a 2nd or 3rd time? It may go nowhere)
 - Forwarding "sanitized" spam samples in complaints may yield URLs that simply don't work, or which work "misleadingly."
 - Forwarding "raw spam samples in complaints "outs" your spam collection infrastructure and may result in "list washing."



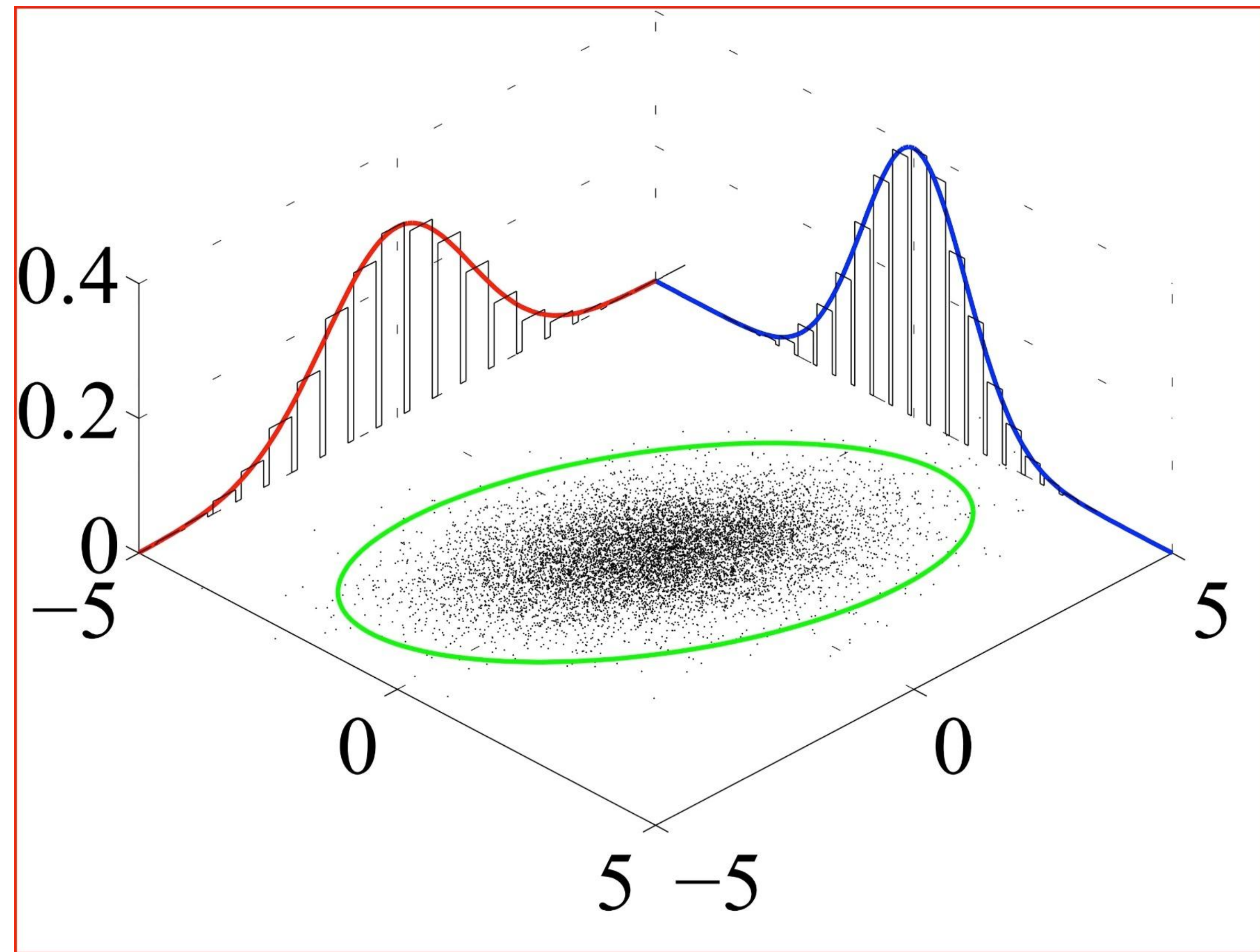
中国互联网安全大会



360互联网安全中心

MULTIVARIATE SOLUTIONS

- In a multivariate approach we look at more than one measurement at the same time
- This allows “interactions” to be accounted for
 - x by itself? okay
 - y by itself? okay
 - x and y *combined together*? **Does NOT work!**
- NOT combining multiple attributes into a single score, compared against a threshold (SPamAssassin style)
- NOT just successive application of independent univariate filters, either



https://commons.wikimedia.org/wiki/File:Multivariate_normal_sample.svg

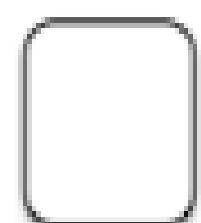
- Currently passive DNS captures data about three main types of DNS-related entities:
 - Names
 - IPs
 - **Name Servers**
- None of that is beautiful continuous data
- If you attempt to visualize it, it will NOT look like the pretty graph on the preceding page

Measurement Options

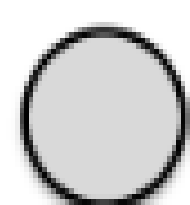
NOMINAL



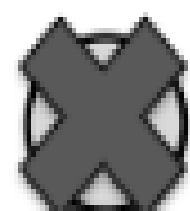
Yes



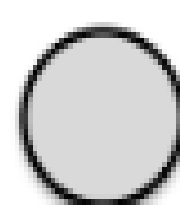
No



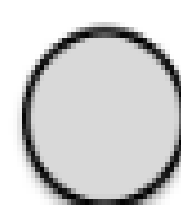
BEEF



FISH



PORK



VEG

ORDINAL

VERY HOT!

Hot

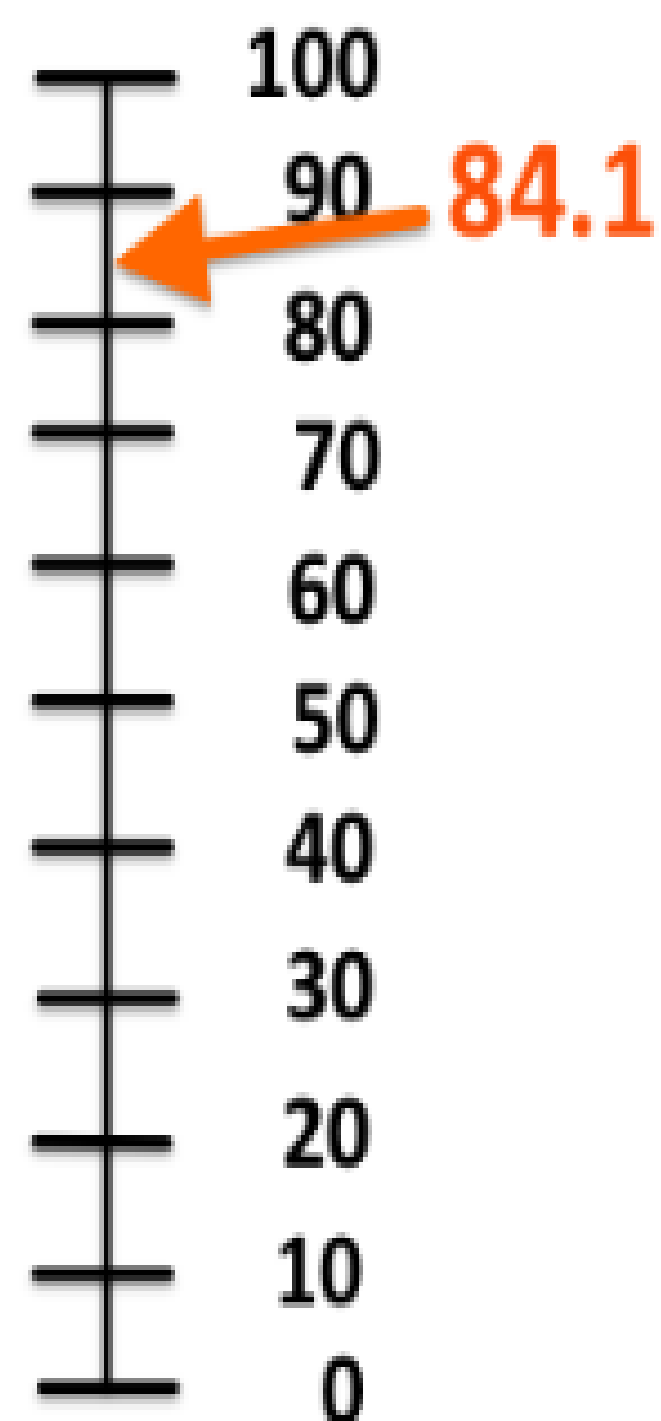
Medium



Mild

Bland

RATIO



Statistical options for nominal data

are limited: you can do cross tabs, **but** (a) that's not very statistically "sexy," and (b) interpretation becomes hard as the table size increases

- Combine passive DNS data with other non-DNS data to go “multivariate”
 - Non-DNS data could be pre-existing data such as domain WHOIS or IP WHOIS data
- Collect new data to augment passive DNS dataset (where active scanning is allowed by law and by your network terms of service)
 - For example, fingerprint/scan hosts with NMAP or a similar scanning tool to see what patterns of ports (if any) are open on a range of IP addresses



中国互联网安全大会



360互联网安全中心

UNDERSTANDING WHOIS and GEOLOCATION

- Create a new domain name
 - Specify the domain you want to register
 - Provide (supposedly accurate) point of contact (POC) details
 - Decide if you want to have those POC details “unlisted” through use of a privacy/proxy registration service
 - Define the authoritative name servers that know how to map your domains to the IP address(es) of your server
 - Pay an annual fee to the registrar
- POC information and related details about most domains get added to an online database - WHOIS

- Clues to registrant “real world” identity in WHOIS
 - Their **name** (but claimed name may be bogus, or someone else’s name used without authorization)
 - A **street address** (can be a 3rd party mail drop, incomplete, fictitious, etc)
 - A **phone number** (may be a prepaid “burner” phone)
 - An email address (may be throw away and only used once)
- If you have the ability to get a court order
 - Their **credit card number** (may be stolen or prepaid or paid using Bitcoin)
 - An **IP address** from which they placed their order, etc.

- Proxy/privacy protection may be free (bundled with a domain's registration), or offered as an extra cost service
- Proxy/privacy services allow registrants to conceal their contact details from public display
- Even if used, LEOs can still seek a court order to strip a domain's proxy/privacy status or to directly obtain underlying details (but this can be a pain and underlying details may still be bogus or require additional deobfuscation) [www.securityskeptic.com/2015/07/how-to-register-a-gtld-domain-name-without-disclosing-personal-data.html]
- Some proxy/privacy service providers may have TOS which allow them to unilaterally remove protections for a domain (if a domain is obviously being misused, e.g. for phishing or SPAM)

- IP addresses may have an associated geolocation (from IP WHOIS)
- IP addresses may ALSO have an associated geolocation from a geolIP database
- Domains may have an associated geolocation (from domain WHOIS)
- IP addresses may have an associated geolocation due to use of a country code TLD

Inconsistencies may be innocent or a sign of something worth scrutiny

- ICANN administers global top level domains (gTLDs) such as .com, .net, .org, .biz, .info, etc.) ICANN requires WHOIS service (although they permit privacy/proxy registrations)
- Country code TLDs (ccTLDs) are run according to their own rules. Some of them have policies which limit public access to the WHOIS data for any/all of their domains [*IF* the WHOIS information actually exists]
 - WHOIS information may only be available and usable by registered users
 - Some WHOIS information may be displayed in graphical format to hinder automated “scrapping” / cut-n-pasting of WHOIS data
 - WHOIS access may be strictly rate limited, with access slowed or blocked altogether after just a handful of domains are checked from the same IP address



中国互联网安全大会



360互联网安全中心

MALICIOUS CAMPAIGNS DURING PUBLIC EVENTS

Getting 'Simple' pDNS Data

```
$ nmsgtool -C ch208 -c 5000000 | grep rrname | awk '{print $2}' | sed 's/.$$/' |  
grep "olym" | grep -v "polymer" > olymp.txt
```

```
$ reverse-domain-names < olymp.txt | sort | uniq -c | sort -nr > temp-olym.txt
```

com.rio-2016-olympics-live.www

com.nbcolympics

ru.club-olym

de.internet-olympiade

com.olympicbiofeedback

com.olympianeagleathletics

za.co.olympicpaints

vn.edu.top-olympia

ru.winterolympics2014

ru.winterolympic-2014

ru.cityolympic

hu.olympingaruhaz

edu.tjhsst.olympus

de.mathematik-olympiaden

net.freakolympics.www

com.olympusrugby

com.olympusdl

com.olymposgozleme

com.franceolympique.cotedor

com.dealsaver.olympia

com.catsummerolympics

com.alltop.cloud.com.olympicssports

- Most new domains (<24 hours) are nefarious
- 60% of SPAM studied used header or envelope domain < 24 hours old
- Most new domains don't yet have a reputation
- NOD as Streams (newly active vs newly observed)
- NOD as Feeds (RPZ – DNS Firewall; RHSBL – Spam Assassin)
- Various intervals available (5m, 10m, 30m, 1hr, 6hr, 12hr, 24hr)

- 1363288-irish-executive-arrested-in-rio-olympics-ticket-raid[dot]page
- derelict-and-deserted-the-ghost-of-former-olympic-sites[dot]page
- helen-skelton-strictly-come-dancing-olympics-bbc[dot]page
- olympic-council-of-ireland-employee-arrested-in-ticket-raid[dot]page
- olympic-diving-pool-turns-green-and-baffles-competitors[dot]page
- olympic-rio-gang-steal-dog-pet[dot]page
- Olympicsgames[dot]club
- rio-2016-diving-pool-green-olympics-tom-daley[dot]page
- rio-olympics-gymnast-breaks-leg-video[dot]page
- Rio2016olympics[dot]today
- rio-olympics2016[dot]online
- Riolympics2016[dot]today
- Riolympicsgame[dot]club
- Riolympics[dot]solutions
- Riolympics[dot]space
- Riolympics[dot]tech
- Riosportsolympics[dot]online
- Olympicsrio2016[dot]online
- Olympicsrio2016[dot]today
- Watchbrazilolympics[dot]online
- watch-olympics16-livesnow[dot]ga
- Watchtheolympics[dot]online
- Winterolympics2018[dot]xyz
- Winterolympics[dot]press

- Dolympic[dot]de
- Esportolympics[dot]nl
- Esportsolympics[dot]nl
- Jordan72016olympic[dot]cc
- Olympicamsterdam[dot]nl
- Olympicbikes[dot]nl
- Olympiccasino[dot]nl
- Olympicconsultants[dot]nl
- Olympiccrowdfunding[dot]de
- Olympiccrowdfunding[dot]nl
- Olympicentertainment[dot]nl
- Olympicgamesnews[dot]de
- Olympichub[dot]nl
- Olympicit[dot]nl
- olympic-klasse[dot]de
- olympic-land[dot]de
- olympic-land[dot]nl
- Olympicland[dot]nl
- Olympicnews[dot]io
- Olympicoffers[dot]de
- olympic-parc[dot]de
- olympic-parc[dot]nl
- Olympicpetfood[dot]nl
- olympic-travel[dot]de
- Olympiccycles[dot]nl
- Radiolympic[dot]nl
- Radiolympics[dot]nl
- Sociolympic[dot]nl
- Sociolympics[dot]nl
- Specialolympics2017[dot]nl
- Theolympic[dot]nl
- Theolympicstandard[dot]biz
- Usolympicsnews[dot]com
- Vrolympics[dot]cn
- Winterolympic2018[dot]net

Parsed WHOIS Record

olympicsgames.club

Whois Record Dates

Created: 08/09/2016 Updated: 08/09/2016

Expires: 08/08/2017

CTB Domain Dates

First seen: 08/12/16 08:01am Last Updated: 08/12/16 08:02am

Last Fetched: 08/12/16 08:02am

Misc. Info

Source: [CyberToolbelt](#)

Whois Server: whois.nic.club

Status:

[clientdeleteprohibited](#); [clientrenewprohibited](#); [clienttransferprohibited](#); [clientupdateprohibited](#)

Whois Contacts

Registrant/	ramaswamyk467@gmail.com
Administrative/	ramesh kumar
Technical/	Dadri Main Rd Bhangel, Salarpur Khadar, Sector 102
Billing/	Noida
As of 08/12/16 08:02am	Uttar Pradesh
	201304
	IN
	Tel: +91.8876586351

olympicsgames.club

Information About 107.180.39.237/32

107.180.39.237

RDNS: ip-107-180-39-237.ip.secureserver.net.

GeoLocation

19 domains hosted

Owner: Godaddy.com Llc

ASN: 26496 | AS-26496-GO-DADDY-COM-LLC

Time Zone: -07:00

Area Code: 480

Location: Scottsdale,US

Registrar: GODADDY.COM

IANA ID: 146

Email:

Queries from:
[www.cybertoolbelt.com](#)

Example 2: WHOIS and GeolIP

7aggi2bq4bms4dfo.onion.to

Parsed WHOIS Record

onion.to

Whois Record Dates

Created: 08/19/2012 Updated:

Expires:

CTB Domain Dates

First seen: 08/19/12 11:45pm Last Updated: 08/13/16 03:46pm

Last Fetched: 08/13/16 03:46pm

Misc. Info

Source: [CyberToolbelt](#) Registrar: whois.tonic.to

Whois Server: whois.tonic.to Email:

Status:

Domains → Whois → Results

7aggi2bq4bms4dfo.onion.to

Tonic whoisd V1.1

onion ns1.cloudns.net

onion ns3.cloudns.net

```
merike@pDNS:~$ domain-to-geoip.py 7aggi2bq4bms4dfo.onion.to
7aggi2bq4bms4dfo.onion.to 185.100.85.150 RO
7aggi2bq4bms4dfo.onion.to 217.197.83.197 DE
7aggi2bq4bms4dfo.onion.to 2001:67c:1400:22b0::1 DE
```

[This product includes GeoLite2 data created by MaxMind, available from www.maxmind.com]

bailiwick **onion.to.**
count 4029
first seen 2012-08-23 19:47:44 -0000
last seen 2012-10-22 15:02:47 -0000

onion.to. AAAA 2001:470:27:17e::2
onion.to. AAAA 2607:f358:1:fed5:22:0:93d0:a29a

bailiwick **onion.to.**
count 201
first seen 2012-08-11 23:54:17 -0000
last seen 2012-08-21 14:29:24 -0000

onion.to. AAAA 2001:470:1f0e:3d5::2

bailiwick **onion.to.**
count 1348760
first seen 2015-06-01 21:53:24 -0000
last seen 2016-08-14 17:54:01 -0000

onion.to. AAAA 2001:67c:1400:22b0::1

bailiwick **onion.to.**
count 196
first seen 2016-01-23 11:23:34 -0000
last seen 2016-01-23 12:55:49 -0000

onion.to. AAAA 2001:67c:1400:22b0::1

onion.to. AAAA 2a06:1700:0:8::1

bailiwick **onion.to.**
count 5943
first seen 2012-08-20 03:56:11 -0000
last seen 2012-11-18 10:05:45 -0000

onion.to. AAAA 2607:f358:1:fed5:22:0:93d0:a29a

bailiwick **onion.to.**
count 126
first seen 2012-11-06 16:49:11 -0000
last seen 2012-11-18 01:30:38 -0000

onion.to. AAAA 2607:f358:1:fed5:22:0:93d0:a29a

onion.to. AAAA 2a00:dcc0:eda:88:245:71:1f43:42a4

bailiwick **onion.to.**
count 15265
first seen 2012-10-22 22:36:00 -0000
last seen 2013-03-19 14:50:33 -0000

onion.to. AAAA 2607:f358:1:fed5:22:5987:c2c4:2127

bailiwick **onion.to.**
count 423
first seen 2012-11-19 00:56:39 -0000
last seen 2013-03-03 19:29:45 -0000

onion.to. AAAA 2607:f358:1:fed5:22:5987:c2c4:2127

onion.to. AAAA 2a00:dcc0:eda:88:245:71:1f43:42a4

IPv6 Reserved Addresses (RFC 6890)

Description	Network
unspecified	:: /128
loopback	::1 /128
IPv4-IPv6 Translation address	64::ff9b::/96
IPv4-compatible IPv6 address	::/96
IPv4-mapped IPv6 address	::ffff:0:0/96
discard-only prefix	100::/64
TEREDO	2001::/32
benchmarking	2001:2::/48
ORCHID	2001:10::/28
6to4	2002::/16
reserved	::/8
unique-local address	fc00::/7
multicast address	ff00::/8
documentation addresses	2001:db8::/32

- Passive DNS is a highly effective tool to enrich threat intelligence and advanced digital investigations
- As Passive DNS grows in use and popularity, users are finding new ways to use the data
- Malicious users obfuscate their digital trail to make connecting the dots of the investigation more difficult
- Work-around techniques around obfuscation include augmenting Passive DNS with new or existing data such as WHOIS or GeolP location
- Understanding the many uses of Passive DNS can help your organization stay ahead of the threat.

Thank You!



中国互联网安全大会



360互联网安全中心